

PROGRESS REPORT

Future Direction

How comprehensive are SBOM specifications?

- How do the recommendations between CycloneDX, SPDX, and CISA differ?
- How does the taxonomy of all recommendations compare to individual specifications?
- To what extent are the recommendations actionable and specific.
- How are recommendations distributed among the different target audiences (SBOM Users, Upstream Suppliers, etc)?
- What is the topic distribution of the recommendations?

Future Direction

To what extent could SBOM specifications prevent real-world security problems?

- Conduct a retrospective study:
 - Review past real-world security failures (e.g. news stories) and collect CVE records.
 - Map these to recommendations in the taxonomy to identify which recommendations from which document might have prevented each failure.
- Analyze which threats can be prevented by SBOMs and which cannot.
- Evaluate each specification's ability to prevent security issues:
 - What percentage of CVEs and news story failures could have been prevented by each specification?

Modified Methodology for SPDX

Following the differences in tables using the old methodology, a qualitative discussion between the two annotators was the basis of a new methodology, which focused on elaborating on potentially unclear aspects of the methodology, alongside a focus on maximising reproducibility.

Notable changes:

1. Different columns for literary keyword and normative keyword to prevent loss of information
2. Defining 'clauses' to also mean clauses derived from tables, figures, and bullet points, and highlighting the need to extract both self contained clauses, and derived clauses separately
3. Reducing the normative keywords to 3: MUST, SHOULD, MAY, to ensure generalisability

Validation of new methodologies

The methodologies were then validated, by the two annotators proceeding to repeat the extraction using the new methodology on a different section of the documentation, and then calculating the similarity.

Old methodology (spdx):

Jaccard similarity: 0.48

New methodology (spdx):

Jaccard similarity: 0.81

Using LLM for Extractions (1/2)

Methodology for NotebookLM:

→ Fed two sources: CycloneDX documentation and SBOM extraction instructions (based on punar's past methodology)

→ Employed the following prompt:

"" I have uploaded two key documents:

- 1.SBOM_Extraction_Rules.txt (this contains detailed instructions for you).
- 2.OWASP_CycloneDX-AuthoritativeGuide.pdf (this is the document to analyze).

Please act according to the persona, methodology, and output requirements detailed in SBOM_Extraction_Rules.txt.

Your task is to analyze ONLY the following sections from the OWASP_CycloneDX-AuthoritativeGuide.pdf:

Introduction

CycloneDX Object Model

Scenarios and Recommendations: General Guidance

Extract information from these sections as per the rules in SBOM_Extraction_Rules.txt and present it in the specified table format.""

→ Compared the recommendations from the table against my extractions.

Scores I got are: **Symmetric F1 Score: 0.887; Jaccard Similarity: 0.80**

Past Gemini 2.5 scores: Symmetric F1 Score: 0.74; Jaccard Similarity: 0.61

Scoring Metrics Old

Jaccard Similarity:

CycloneDX (Punar&Abdullah): 0.64

CycloneDX (LLM&Abdullah): 0.61

SPDX(Punar&Huzaifa): 0.45

CISA (Abdullah&Huzaifa): 0.58

Symmetric F1:

CycloneDX (Punar&Abdullah): 0.78

CycloneDX (LLM&Abdullah): 0.74

SPDX(Punar&Huzaifa): 0.0.622

CISA (Abdullah&Huzaifa): 0.733

Scoring Metrics New

Jaccard Similarity:

CycloneDX (Punar&Abdullah): 0.6981

CycloneDX (LLM&Abdullah): 0.80

SPDX(Punar&Huzaifa): 0.48

CISA (Abdullah&Huzaifa): 0.67

Symmetric F1:

CISA (Abdullah&Huzaifa): 0.800

CycloneDX (LLM&Abdullah): 0.887

**THANK
YOU**